MacZine

THE MACTECH SOLUTIONS NEWSLETTER
ISSUE Nº 049 · OCTOBER 2026 · MACTECHSOLUTIONSLLC.COM/MACZINE

FIELD REPORT · CUI ENCLAVES

Enclave Inheritance: Ask for the Matrix Behind the Percentage

Enclave vendors quote a percentage of controls inherited. It means nothing without the responsibility matrix behind it. How to read one, row by row.

BY **PATRICK CARUSO**

READING TIME · 7 MIN

CUI-ENCLAVE · CMMC · NIST-800-171 · RESPONSIBILITY-MATRIX · INHERITANCE

Every managed enclave vendor in the CMMC market now quotes an inheritance figure. Eighty percent of technical objectives inherited. Most controls covered. Ninety of a hundred and ten. The figures are not lies, exactly. They are answers to a question the vendor chose, and the question is rarely printed next to the number.

Here is the direct answer to the question you should be asking instead. Before you sign for any enclave, ask for the customer responsibility matrix: the row-by-row statement, for every NIST SP 800-171 requirement, of what the vendor does, what you still do, and what evidence you are expected to keep. If the vendor cannot produce it, the percentage was marketing. If they can, the percentage becomes checkable, and the matrix itself becomes the first page of your System Security Plan.

MacTech publishes ours, and this piece uses it as the worked example, not because it is flattering but because it is the one we can show you row by row. It sits at mactechsolutionsllc.com/vault/responsibility-matrix with a CSV download, and the numbers in the margin come from the same file our own assessment package is generated from.

FIELD COPY
ISSUE Nº 049
CUI ENCLAVE

64 / 44 / 2

OF 110 NIST SP 800-171 CONTROLS THE MACTECH MANAGED CUI VAULT CARRIES, SHARES, AND LEAVES WITH THE SUBSCRIBER

What "inherited" is allowed to mean

NIST SP 800-171 does not define inheritance. The concept comes from the Risk Management Framework, where a *common control* is one that a provider implements once and many systems rely on. CMMC's assessment guide carries a narrower version: an organization seeking certification may rely on an external service provider for a requirement, and the assessor will look for the provider's evidence that the requirement is met, plus the customer's evidence that they use the service as designed.

That second half is the part the percentage hides. Almost no requirement is inherited outright. The provider encrypts the disk; you still decide what goes on it. The provider enforces multifactor authentication; you still decide who gets an account and when it is removed. In our matrix only two of a hundred and ten rows are wholly the subscriber's, but forty-four are shared, and shared means an assessor will ask you for something.

320

ASSESSMENT OBJECTIVES AN ASSESSOR ACTUALLY SCORES - A MATRIX WRITTEN AT THE CONTROL LEVEL, LIKE OURS, IS ONE STEP COARSER THAN THE SCORE

22

OF THE 64 PROVIDER-CARRIED ROWS THAT RIDE ON MICROSOFT AZURE UNDER A SECOND, SEPARATE MATRIX

A control the vendor "carries" is a control you will still be asked about. What changes is what you have to produce: a statement that you use the service as designed, and the evidence that you do.

How to read a matrix: five questions

Which axis is it? A hosted enclave has two providers above you: the cloud platform and the enclave operator. Microsoft's own responsibility statements for Azure cover what Microsoft does; they say nothing about what the company operating your enclave on Azure does. A matrix worth reading is the operator-versus-you axis, and it marks

which of its provider rows in turn ride on the cloud platform. In ours, twenty-two of the sixty-four provider rows are flagged that way, covering physical protection, maintenance, media handling and the cryptography at rest that Azure implements underneath us. Those twenty-two rows are only as strong as the Azure attestation behind them, and an assessor is entitled to ask for that too.

What granularity? The assessment methodology scores 320 objectives. A matrix written at the control level, which is what nearly every vendor including us publishes, is one step coarser than the score. When a control is marked shared, the honest reading is that some of its objectives are the vendor's and some are yours, and the matrix has not yet said which. Our page states this in its second paragraph, because a matrix that implies objective-level precision it does not have is worse than no matrix.

What does the customer statement actually ask of you? Every shared row should carry two sentences: what the provider does, and what you do. Read the second one as a task list. In our matrix, row 3.1.1 (limit system access to authorized users) has MacTech operating the identity platform and enforcing the policy, and the subscriber approving who is on the access list and reviewing it on a cadence. That review is your evidence. If a vendor's matrix has the provider statement filled in and the customer column blank, the vendor has described their product, not your assessment.

Where is the evidence you keep? The best matrices list, per shared row, the artifact the subscriber is expected to retain: the access-review record, the training completion, the signed acceptable-use acknowledgement, the marking decision. That column is the difference between a matrix and a brochure. It is also what turns the enclave into a scope-reduction argument you can defend: the assessor sees a short, named list of what you own.

Can you get it as data? A PDF is a promise. A CSV with a checksum is a record. Ours carries the SHA-256 of the source file on the page and in the download's headers, so the matrix you read in the sales conversation is provably the one in the assessment package six months later.

> ◆ TWO MATRICES, NOT ONE
>
> Every hosted enclave has two responsibility axes. One is the cloud platform versus the enclave operator (Microsoft versus MacTech, in our case). The other is the enclave operator versus you. A vendor's "inherited" figure is only meaningful if you know which axis it is counting, and whether the rows that ride on the cloud provider are marked as such.

> ◆ OBJECTIVES, NOT CONTROLS
>
> An assessor scores 320 objectives, not 110 controls, and a control fails if any one of its objectives does. A matrix that says "shared" at the control level is telling you that some of that control's objectives are yours; it is not yet telling you which. Ask.

Where the two rows that stay yours came from

It is worth looking at the two rows no enclave can take. The first is 3.2.2, training personnel to carry out their security responsibilities. The enclave can host the training platform and record the completions; it cannot make your engineers take the course. The second is 3.8.4, marking media with CUI markings and distribution limitations. Marking is a decision made by the person who knows what the file is. No boundary can decide that for you, and a vendor who claims otherwise is telling you they do not understand what makes a file CUI in the first place.

Those two rows are the honest floor of any enclave. Everything above them is a negotiation about how much of the shared work the operator will carry, and at what price.

The family view

Read by control family, the matrix says something about where an enclave earns its keep. System and Communications Protection is the clearest case: all sixteen rows are the provider's, because the boundary, the cryptography and the network are the enclave. Configuration Management is nine of nine for the same reason. Audit and Accountability is eight of nine, which is where continuous monitoring inside the boundary pays for itself.

The families that stay shared are the ones about people and places. Physical Protection is six shared rows, because the datacenter is Microsoft's and the laptop your engineer uses to reach it is not. Personnel Security is two shared rows. Awareness and Training is two shared and the one customer row above. Incident Response is three shared, because the operator can detect and contain inside the boundary but only you can decide what to report to whom.

If a vendor's matrix marks Physical Protection or Personnel Security as fully inherited, ask how. The answer is usually that they have scoped your workstations out of the assessment boundary, which is a legitimate architecture and a claim you will need to defend with a boundary diagram, not a matrix.

What to do with it

Take the vendor's matrix, or ours, and do three things before you sign.

Count the shared rows and read every customer statement as a task with an owner. If nobody on your staff can be named against a row, that row is not shared. It is unaddressed.

Pull the rows flagged as riding on the cloud platform and ask the vendor for the platform attestation they rely on. For Azure Government or Commercial that is a FedRAMP package; for anything else, ask what it is.

Put the matrix in the SSP as an appendix and cite it, row by row, in the control narratives. An assessor who can walk from your narrative to the provider's statement to the evidence you kept is an assessor who is not going to spend an afternoon on the enclave.

The percentage will still appear in the sales deck. Now you know what it is a percentage of. ◆

MORE ISSUES
mactechsolutionsllc.com/maczine
new field copies with every merge

WORK WITH US
CMMC readiness · CUI enclaves · RMF
mactechsolutionsllc.com/contact

MACZINE
Written, reviewed and versioned in the open.
Published from Git, reviewed like code.